

THREAT INTELLIGENCE & INCIDENT REPORT

Suspicious Email, Domain & Source Code Investigation

Name	SOC Analyst (Student)	Status	UNDER INVESTIGATION — ESCALATED
Sender Domain	[redacted].com	Linked Domain	[redacted].info
Email Subject	TCS - Update on Available Role (0-2 Yrs)	Severity	HIGH

Data Handling Notice

All indicators of compromise (IOCs), domains, URLs, IP addresses, and identifiers in this report have been anonymized and defanged to prevent misuse. This report is intended strictly for educational and cybersecurity research purposes.

1. Executive Summary

This report analyses a sustained phishing and social engineering campaign identified on April 24, 2026, based on the receipt of 11 unsolicited recruitment emails from the sender "support@[redacted].com." The emails advertise job opportunities across multiple organizations, including Tech Mahindra, Tata Consultancy Services, and Infosys, indicating a non-targeted, high-volume distribution approach aimed at job seekers. Each email contains embedded links directing users to the domain [redacted].info, which has been observed hosting job listings with consistent redirect and tracking behavior.

Analysis of the associated infrastructure reveals the use of a lookalike sender domain, brand impersonation, Google AdSense integration for traffic monetization, and parameterized tracking identifiers (e.g., cmid) enabling per-recipient click tracking. The website operates on a PHP-based content management system (PHPKB), allowing scalable generation of job postings across multiple companies. The repetition of similar email templates and shared infrastructure across 11 messages strongly indicates an automated campaign. Based on these findings, the threat actor is assessed, with medium-high confidence, to be operating a job-scam and ad-fraud hybrid campaign that relies primarily on social engineering and trust exploitation rather than malware delivery.

2. Email Header & Sender Forensics

2.1 Raw Email Header Summary

Header Field	Value / Analyst Observation
From	< support@[redacted].com >

Reply-To	< support@[redacted].com > — Reply-To matches From. No reply-chain hijack detected, but sender domain is suspicious.
Date	April 24, 2026 at 11:15 AM local time
Subject	TCS - Update on Available Role (0-2 Yrs) — Social engineering lure targeting Indian job-seeking freshers. Falsely implies TCS correspondence.
Mailed-By	[redacted].com — Sending mail server is the same domain as the sender. Domain is NOT [redacted].info but [redacted].com. Distinct from the linked domain — two-domain operation.
Signed-By (DKIM)	[redacted].com — DKIM signature present and matches sending domain. Email is NOT spoofed at the transport layer — the actor controls [redacted].com and sends legitimately signed mail.
TLS Security	Standard TLS encryption in transit. Expected. Does not indicate legitimacy of content.

CRITICAL FINDING — Domain Duality:

The sending domain ([redacted].com) and the linked domain ([redacted].info) are DISTINCT entities. This is a two-domain operation. The actor uses [redacted].com as the spam/email delivery infrastructure and [redacted].info as the content/landing page. This separation is a deliberate operational security (OPSEC) technique to ensure that if one domain is blocked or burned, the other survives. Both domains must be treated as IOCs and blocked independently.

2.2 Sender Domain Assessment — [redacted].com

Attribute	Assessment
Domain	[redacted].com — Domain exhibits lookalike/typosquatting characteristics intended to mimic legitimate brands.
DKIM Status	SIGNED — Actor controls the domain and has configured DKIM. This bypasses basic email authentication checks and may evade spam filters that rely on DKIM validation alone.
Sender Identity	Display name: ' support' — generic, designed to appear as a legitimate job notification service.
Impersonation Target	TCS (Tata Consultancy Services) and Infosys — both Tier-1 Indian IT corporations. Impersonation of known employers constitutes targeted social engineering.
Recommendation	BLOCK [redacted].com at email gateway (SEG). Add to DNSBL if supported. Flag all inbound mail from this domain for quarantine.

3. Malicious URL & Campaign Tracking Analysis

The email body contained two URLs. Both utilize the parameterized /question.php path on [redacted].info, which was previously confirmed to execute an HTTP 302 redirect. The parameters embedded in these URLs are highly significant from a threat intelligence perspective.

3.1 URL 1 — TCS Walk-In Drive Lure (Primary)

```
hxxps://[redacted].info/question.php?ID=609&title=Direct-Walk-In-Drive-at-Tata-Consultancy-Services-(TCS)&cmid=72d00f-1984-4ad2-8bba-83fd83cb26a1
```

URL Parameter	Value & Significance
ID	609 — Sequential article/entry ID in the PHPKB CMS database. Confirms the underlying platform is PHPKB Knowledge Base Script.
title	Direct-Walk-In-Drive-at-Tata-Consultancy-Services-(TCS) — SEO-optimized slug. Confirms deliberate TCS brand impersonation for search engine poisoning and social engineering.
cmid	[redacted] — UUID v4 Campaign/Click ID. This is a per-email or per-recipient tracking identifier. Enables the threat actor to track exactly which recipients clicked this link, when, and from what IP. Constitutes active victim enumeration.

3.2 URL 2 — Infosys Full Stack Developer Lure

```
hxxps://[redacted].info/question.php?ID=615&title=%C2%A0Infosys-Is-Hiring-|-Full-Stack-Developers-(2024-&-2025-Batch)
```

URL Parameter	Value & Significance
ID	615 — Higher sequential ID than URL 1. Indicates more recently added entry in the CMS database.
title	Infosys-Is-Hiring- -Full-Stack-Developers-(2024-&-2025-Batch) — Note: %C2%A0 at start is a URL-encoded non-breaking space (U+00A0). May be used to bypass URL pattern matching in email security filters.
cmid	ABSENT — This URL has no campaign ID. May be a secondary/fallback link, or the actor inadvertently omitted the tracker. Reduces tracking capability on this link.

Technical Observation — URL Filter Evasion:

The presence of %C2%A0 (URL-encoded non-breaking space) at the beginning of the second URL title parameter is a potential filter evasion technique. Some email security gateways and URL reputation engines perform pattern matching on decoded URL strings. Injecting a non-breaking space at the start of a known brand name (Infosys) may cause the URL to fail a simple substring match against known brand impersonation patterns.

4. HTML Source Code Analysis

4.1 CMS Platform Identification

The page source contains the following meta tag, definitively identifying the underlying CMS:

```
<meta name="generator" content="PHPKB Knowledge Base Script">
```

PHPKB is a commercial PHP-based knowledge base and FAQ management system. Its use here as a job-posting platform is atypical and may indicate the site was repurposed from a legitimate use-case, or that PHPKB was selected for its low cost and ease of deployment. This identification enables further OSINT on the CMS version for known CVEs.

4.2 Google AdSense Monetization — Strong indicators of Ad-fraud Monetization:

The most significant finding in the source code is the presence of an active Google AdSense script:

```
<script async src="
  https://[redacted].info/pagead2.googleadsyndication.com/pagead/js/adsbygoogle.js?client=ca-
  pub-[redacted]" crossorigin="anonymous"></script>
```

Attribute	Finding
AdSense Publisher ID	ca-pub-[redacted] — This is a uniquely identifying Google AdSense account ID. It can be used to report the account to Google for policy violations (spam / deceptive content monetization).
Implication	The primary financial motive of this operation is AD REVENUE FRAUD. The actor drives traffic to [redacted].info via spam emails, causing victims to load AdSense ads, generating fraudulent ad impressions and click revenue. This is a textbook ad-fraud / MFA (Made-For-Advertising) spam operation.
Action Required	Report Publisher ID ca-pub-[redacted] to Google AdSense abuse team at: support.google.com/adsense/troubleshooter/1190500. This may result in account termination and disruption of the actor's revenue stream.

4.3 Statcounter Tracking — Confirmed Visitor Intelligence Harvesting

As documented in Rev. 1, Statcounter is embedded. The source code confirms the exact configuration:

```
var sc_project=[redacted]; var sc_invisible=1; var sc_security="[redacted]";
```

sc_invisible=1 confirms the tracking pixel is set to invisible mode — visitor tracking occurs with no visible indicator on the page. The security hash ([redacted]) combined with project ID ([redacted]) is a unique fingerprint for this Statcounter account and can be reported to Statcounter for abuse investigation.

4.4 JavaScript Library — Potential Vulnerability Surface

The page loads the following legacy JavaScript library inline:

```
<script language="javascript" src="include/overlib.js" type="text/javascript"></script>
```

overlib.js is an outdated JavaScript tooltip/popup library. The use of the deprecated language attribute (language="javascript" rather than type="text/javascript") indicates aged, unmaintained code. This library may contain known XSS or injection vulnerabilities if an unpatched version is in use, representing a potential attack surface if this infrastructure is repurposed or compromised.

4.5 No-Cache Pragma & Conditional Content Delivery

```
<meta name="pragma" content="no-cache">
```

The no-cache pragma, combined with the previously confirmed 302 redirect behavior, suggests the server is configured to deliver dynamic, session-aware content. This supports the hypothesis that the /question.php path may serve different content to different visitors based on parameters such as User-Agent, IP geolocation, or referral source — a technique known as cloaking, commonly used to show legitimate content to crawlers while serving malicious content to targeted victims.

4.6 Content Structure — Confirmed Empty Article Body

The HTML source reveals the article body (ID=[redacted], TCS Walk-In Drive) contains NO actual job posting content:

```
<div class="entry-content"> </div><!-- .entry-content -->
```

Despite the email and page title referencing a specific TCS Walk-In Drive, the article content div is completely empty. This is a critical finding — the lure works purely on brand name recognition in the email subject/URL, with no substantive content delivered. The sole purpose of the page visit is to generate ad impressions and Statcounter visitor tracking data.

5. Updated Indicators of Compromise (IOCs)

IOC Type	Value	Context	Confidence
Domain	[redacted].com	Email sending domain. DKIM-signed. Typosquat/lookalike. Spam/phishing delivery infrastructure.	HIGH
Email Address	support@[redacted].com	Sender and Reply-To address. Actor-controlled mailbox on malicious domain.	HIGH
Domain	[redacted].info	Content/landing page domain. Confirmed redirect abuse, empty content, ad-fraud hosting.	HIGH
IPv4	35.213.xxx.xxx	Primary server IP. Google Cloud AS15169, Singapore. Hosting [redacted].info.	HIGH
IPv4	172.66.xxx.xxx	Cloudflare CDN AS133. Serving Statcounter analytics.	MEDIUM
URL	[redacted].info/question.php?ID=609&cmid=72d8500f...	TCS impersonation lure URL with per-campaign tracking UUID. Victim enumeration enabled.	HIGH

URL	[redacted].info/question.php?ID=615&title=%C2%A0Infosys...	Infosys impersonation URL. %C2%A0 evasion character in title parameter.	HIGH
Campaign ID	72[redacted]	UUID v4 campaign/click tracking ID embedded in URL. Unique per-victim or per-campaign identifier.	HIGH
AdSense Publisher	ca-pub- [redacted]	Google AdSense account monetizing fraudulent traffic. Report to Google for account suspension.	HIGH
Statcounter Project	ID: [redacted] / Hash: [redacted]	Visitor intelligence harvesting. Invisible tracking pixel. Report to Statcounter abuse team.	HIGH
CMS Platform	PHPKB Knowledge Base Script	Identified via meta generator tag. Enumerate known CVEs for installed version.	MEDIUM
JS Library	include/overlib.js	Legacy tooltip library. May carry known XSS vulnerabilities in unpatched versions.	LOW

6. Threat Actor Profile & Campaign Assessment

Attribute	Assessment
Campaign Type	Ad-Fraud / MFA (Made-For-Advertising) spam campaign with secondary job-scam social engineering component.
Primary Motive	FINANCIAL — Google AdSense ad impression/click revenue generation via spam-driven traffic. Secondary motive may include personal data collection via Statcounter.
Target Demographics	Indian IT job seekers, recent graduates (2024-2025 batch), professionals with 0-2 years experience. Highly specific targeting suggests a curated mailing list.

Technical Sophistication	LOW-MEDIUM. Actor demonstrates awareness of DKIM configuration, URL parameter tracking, and basic filter evasion (%C2%A0). Does not demonstrate advanced malware capability.
Infrastructure Separation	Two-domain OPSEC model [redacted].com for (email), [redacted].info for (content). Intentional separation to survive partial takedowns.
Victim Enumeration	CONFIRMED via cmdid UUID parameter in URL 1. Actor tracks which email recipients click links, enabling list hygiene and future targeted campaigns.
Attribution Confidence	MEDIUM. Infrastructure points to India-targeted operation with Singapore-hosted infrastructure. Full attribution requires additional telemetry (email headers beyond To/From, WHOIS, registrar data).

7. Risk Assessment

Risk Factor	Rating	Basis
Ad-Fraud / Revenue Theft	CONFIRMED	Active AdSense publisher ID monetizing spam-driven fraudulent traffic.
Brand Impersonation (TCS, Infosys)	CONFIRMED	Email subject and URL slugs explicitly impersonate TCS and Infosys. Constitutes fraud and trademark violation.
Victim Click Tracking	CONFIRMED	UUID cmdid parameter enables per-recipient tracking. Any employee who clicked is enumerated by the actor.
Data Harvesting (Statcounter)	CONFIRMED	Invisible Statcounter pixel harvests IP, browser fingerprint, and behavioral data of all page visitors.
Phishing / Credential Harvesting	MEDIUM (Unconfirmed)	Empty article body currently. Conditional content delivery may serve credential forms to targeted victims.
Malware Delivery	LOW (Unconfirmed)	No scripts or downloads detected. Cannot rule out conditional delivery via cloaking.
Legal / Regulatory Exposure	MEDIUM-HIGH	Employee PII (IP address, device fingerprint) transmitted to actor-affiliated third-party analytics. Potential PDPA/DPDP Act implications.

8. Recommendations & Action Items

Immediate (0–24 Hours)

-
- BLOCK both domains at perimeter: [redacted].com (email gateway/SEG) and [redacted].info (web proxy/firewall/DNS sinkhole). These are separate infrastructure assets and must be blocked independently.
 - QUARANTINE all inbound emails from [redacted].com. Retroactively search mail logs for any prior delivery from this domain or sender address.
 - HUNT in SIEM/proxy logs for connections to 35.213.xxx.xxx and [redacted].info from any internal endpoint in the past 30 days. Any employee who visited has had their IP and device data harvested.
 - ALERT affected users — any employee who clicked either URL should be notified immediately. Advise password changes as a precaution and request they report any subsequent suspicious contact or job-related solicitation.
 - PRESERVE all email artifacts (raw .eml with full headers) for forensic chain of custody before deletion.

Short-Term (24–72 Hours)

- REPORT AdSense Publisher ID ca-pub-[redacted] to Google AdSense policy team. Reference: support.google.com/adsense/troubleshooter/[redacted]. Include this report as supporting documentation.
- REPORT Statcounter Project [redacted] to Statcounter abuse team for unauthorized visitor surveillance in a spam campaign context.
- WHOIS investigation on [redacted].com — obtain registrar, registration date, registrant details (if unredacted), and name server data. Compare with [redacted].info WHOIS for common registrant attribution.
- ENUMERATE PHPKB CVEs — identify the installed version of PHPKB Knowledge Base Script and cross-reference against known vulnerabilities in the NVD and exploit databases.
- SUBMIT both domains to VirusTotal, URLhaus, PhishTank, and OpenPhish for community intelligence tagging.

Long-Term / Strategic

- ESCALATE to relevant brand protection / legal teams regarding TCS and Infosys impersonation. Both companies have active cyber threat reporting mechanisms and may initiate independent takedown proceedings.
- UPDATE email security gateway rules to flag and quarantine emails containing: (a) links to domains with URL-encoded non-breaking spaces (%C2%A0) in parameters, (b) [redacted]* domain pattern (typosquat family), and (c) job-lure subject lines with company name + experience bracket patterns.
- SHARE IOCs through appropriate threat intelligence sharing channels (ISACs, industry partners) to protect peer organizations in the same sector from the same campaign.
- REVIEW and reinforce employee security awareness training, specifically targeting job-application-themed phishing as a social engineering vector.

9. Notes & Final Assessment

This investigation has evolved from an initial domain reputation query into a fully documented multi-indicator campaign analysis. The evidence collectively indicates a financially motivated, India-focused spam actor operating an ad-fraud campaign, using job-scam social engineering as the primary delivery mechanism. The threat actor demonstrates moderate technical capability, including proper DKIM configuration, UUID-based click tracking, and basic URL encoding techniques for filter evasion, placing them above low-skill actors but significantly below advanced persistent threat (APT) levels.

The most operationally significant findings of this analysis include the confirmation of Google AdSense monetization as the primary revenue mechanism, providing a direct disruption pathway through reporting to Google, and the presence of UUID-based campaign tracking parameters, which confirm active victim enumeration. Additionally, the complete absence of meaningful content within the landing page indicates that the site serves no legitimate informational purpose and is designed solely to generate ad revenue through spam-driven traffic. This case is assessed as HIGH severity and remains open pending further email gateway telemetry analysis, SIEM-based hunting results, and WHOIS-based attribution efforts. All findings are based on passive OSINT, email header analysis, and static HTML source code review, with no active interaction performed against the threat actor's infrastructure.

The campaign avoids traditional malware-based detection mechanisms and instead relies on psychological manipulation and abuse of trusted platforms, significantly increasing its effectiveness against standard security controls.

10. Evidence

Figure 1: Email Screenshot (Phishing Source)

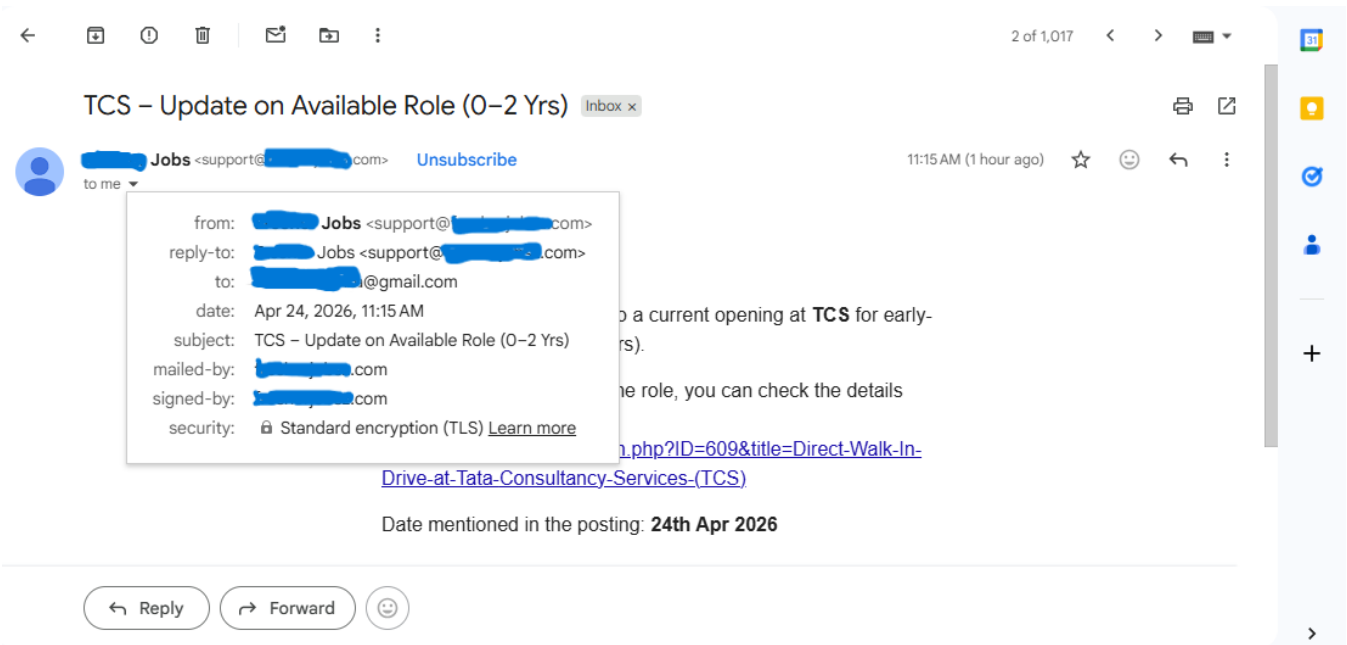


Figure 2: Email Screenshot

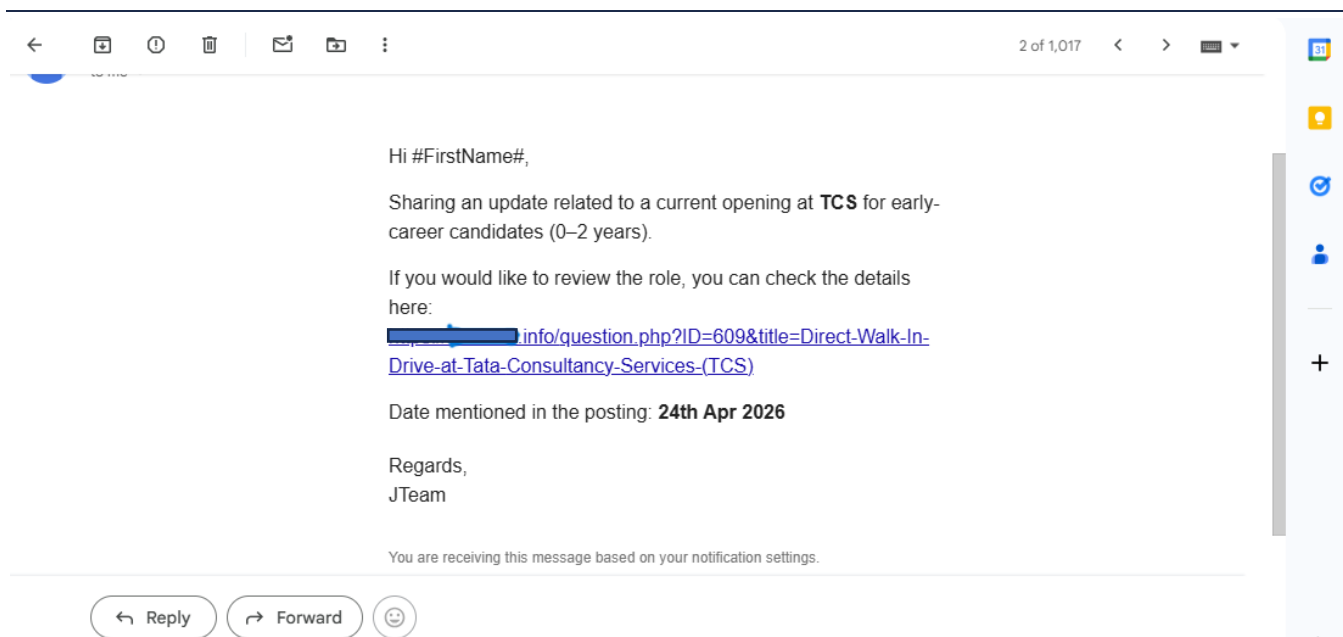
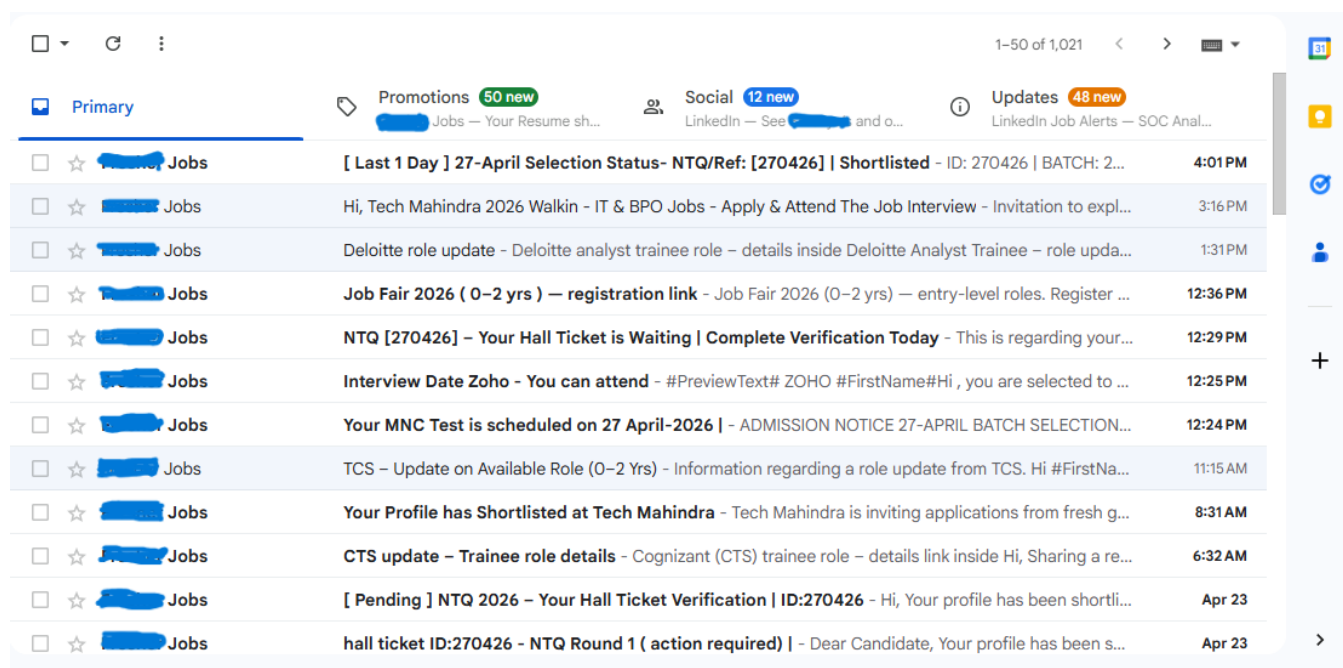


Figure 3 : Email Inbox View Showing Multiple Campaign Messages



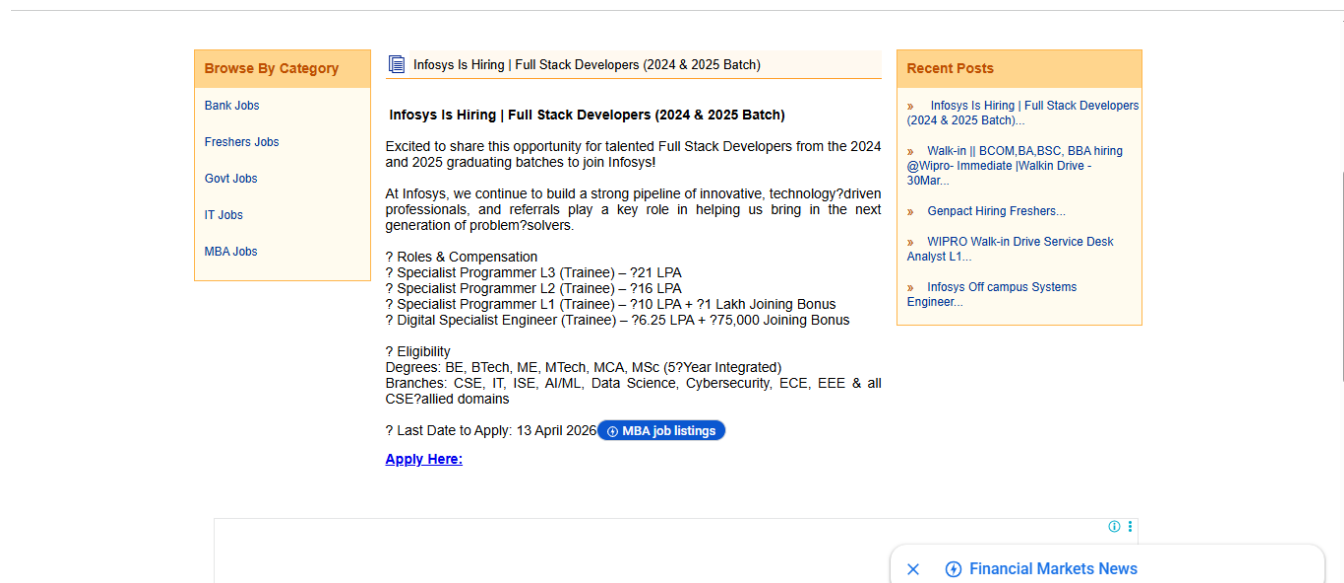
Description: Suspicious recruitment email with unverified sender.

Figure 4 – Website Homepage



Description: Job listing impersonating Infosys.

Figure 5 – External Redirect



Description: “Apply Here” link redirects to external platform.

Code Snippet

1. External Advertising Script (Monetization Indicator)

```
<script async src="hxtps://[redacted-domain]/adsbygoogle.js?client=ca-pub-[redacted]">crossorigin="anonymous"></script>
```

Observation: The presence of Google Ads suggests the platform is monetizing user traffic, which aligns with content-farm or scam-driven engagement models.

2. Tracking Script (User Monitoring)

```
<script type="text/javascript"
src="hxtps://www.statcounter.com/counter/counter.js"
async></script>
```

Observation: The website uses Statcounter analytics to track user activity, indicating monitoring of visitor engagement and potential profiling.

3. Local Script (Injection Risk)

```
<script language="javascript" src="include/overlib.js" type="text/javascript"></script>
```

Observation: A locally hosted JavaScript file (overlib.js) introduces a potential risk, as it could be modified to execute malicious client-side code if the server is compromised.

4. Dynamic Routing (Backend Structure)

```
<a href="question.php?ID=615&title= Infosys-Is-Hiring-|-Full-Stack-Developers-(2024-&-2025-Batch)">
```

Observation: The use of parameterized URLs (question.php?ID=...) suggests a backend-driven content system, which may be used to generate multiple similar job postings at scale.

— END OF REPORT —
